

GDPR Audit

What EU law actually requires of a marketing website in 2026, checked line by line against the new Wergonic landing page — and against the site the public sees today. Every finding was verified in the code or against the live server; nothing here is carried over from an older document.

3 September 2026

New site read against `wergonic-landing-page` · `main` · `f66badc` (2 Sep 2026)

Live site checked directly: `wergonic.com` → `wergonic.se`, plus `cloud.wergonic.com/privacy-policy`

VERDICT

Not compliant today — on either site. The new one is close; the live one is the real exposure.

The new landing page is **architecturally excellent**: no cookies, no analytics, no trackers, no third-party requests of any kind, fonts self-hosted at build time. That is a better starting position than most companies ever reach, and it removes the single biggest source of GDPR fines. **The gap is paperwork and consent mechanics, not architecture** — roughly two to three days of work.

But the site the public reaches at **wergonic.com right now is still the old WordPress site at wergonic.se**, and its privacy policy is the **unedited WordPress sample template**. It talks about blog comments and Gravatar. It does not mention the contact forms that are actually on the page, does not name the company, and gives no legal basis, no retention and no complaint route. That is a plain Article 13 failure on the page the public actually loads.

Timing matters this year. The EDPB's 2026 coordinated enforcement action — 25 national regulators acting together — is **specifically about transparency and privacy notices** under Articles 12–14. This is the one thing being actively audited across Europe in 2026, and it is exactly where both sites fail.

6

MUST FIX BEFORE
LAUNCH

7

SHOULD FIX

5

MINOR

6

ON THE LIVE SITE

Part A · What the law actually requires

The full set of obligations that apply to a B2B marketing website operated by a Swedish company. This is the checklist Part B is scored against.

1 · TELL PEOPLE WHAT YOU DO WITH THEIR DATA — ARTICLE 13

Whenever you collect personal data directly from someone — a contact form, a download form, a newsletter box — you must tell them, *at that moment*, all of the following: who the controller is (legal name, address, contact details), the DPO's contact details if you have one, what you collect, why, the legal basis for each purpose, who else receives it (including hosting and email providers), whether it leaves the EU and under what safeguard, how long you keep it, their rights, and their right to complain to the supervisory authority. In Sweden that is IMY, Integritetsskyddsmyndigheten.

Two things regulators are strict about: the information must be **accurate** — a template that describes data you don't collect is itself a breach of Article 5(1)(a) — and one central policy page is **not enough on its own**. Each collection point needs its own short, contextual notice next to the form, linking to the full policy.

2 · HAVE A LAWFUL BASIS FOR EVERY PURPOSE — ARTICLE 6

Replying to a business enquiry: legitimate interest, or steps prior to a contract. Sending a whitepaper somebody asked for: performance of a contract, or legitimate interest. Adding that person to a marketing list afterwards: **consent**, and consent only. These are three separate purposes and each needs to be named separately in the notice.

3 · IF YOU RELY ON CONSENT, IT MUST BE REAL — ARTICLES 4(11) AND 7

- **Freely given.** You cannot make a download conditional on accepting marketing. If the person cannot get the resource without ticking the marketing box, the consent is invalid.
- **Specific.** One tick box per purpose. Bundling "send me this file" with "send me future emails" into a single checkbox does not work.
- **Unambiguous.** Active opt-in. No pre-ticked boxes, no implied consent.
- **Provable.** Article 7(1) puts the burden on you: you must be able to demonstrate *who* consented, *when*, and to *exactly what wording*. A checkbox that is only validated in the browser proves nothing.
- **Withdrawable**, and as easy to withdraw as it was to give — so a working unsubscribe link.

Separately, Swedish marketing law (marknadsföringslagen §19) requires prior opt-in for commercial email to individuals, with a narrow existing-customer exception. So the consent record is not optional in Sweden even for B2B addresses.

4 · ASK BEFORE STORING ANYTHING ON THE VISITOR'S DEVICE — EPRIVACY ARTICLE 5(3)

This rule covers cookies *and* localStorage, sessionStorage, service-worker caches and fingerprinting. Consent is required before writing anything that is not strictly necessary to deliver what the visitor asked for. Two things are exempt: storage needed to make the site work, and a preference the visitor set themselves — a language or theme choice.

Note on the 2026 state of play: the Commission's Digital Omnibus proposal (Nov 2025) would move these rules into the GDPR and relax parts of them, but it is **still a proposal**. Realistic adoption is late 2026 at the earliest, application 2027. Nothing has changed yet, and consent before non-essential storage is still the rule.

5 · HANDLE RIGHTS REQUESTS — ARTICLES 15-22

Access, rectification, erasure, restriction, portability, objection, and withdrawal of consent. One working address, and a one-month response deadline. Objection to direct marketing is absolute — you must stop, no balancing test.

6 · DON'T KEEP IT FOREVER — ARTICLE 5(1)(E)

Every category of data needs a defined retention period, stated in the notice and actually applied. "Until we no longer need it" is not a period. Form submissions sitting in a shared inbox indefinitely is the most common failure of this rule.

7 · COVER YOUR PROCESSORS AND ANY TRANSFERS — ARTICLES 28 AND 44-49

Anyone who touches the data on your behalf is a processor and needs a data processing agreement: the host, the CDN, the email provider, the mailbox provider, the error tracker. They must be disclosed by category in the notice. Any transfer outside the EEA needs Standard Contractual Clauses plus a transfer impact assessment.

8 · SECURE IT — ARTICLE 32

TLS, current patched software, access control, and protection against abuse of any endpoint that sends mail or accepts input. An unpatched, end-of-life web server holding form submissions is a direct Article 32 problem, independent of anything on the page.

9 · KEEP AN INTERNAL RECORD — ARTICLE 30

A record of processing activities. Not public, but the first thing a regulator asks for.

10 · THE SWEDISH COMPANY-INFORMATION DUTY — NOT GDPR, SAME FOOTER

Lag (2002:562) om elektronisk handel §8 requires any commercial website to make **easily, directly and permanently accessible**: the legal name, the geographic address, the email address, the corporate identity number (organisationsnummer) and the VAT number. This is separate from GDPR and often forgotten.

Part B · The new landing page

Read against `main` at `f66badc`. This is the site that will replace wergonic.com.

VERIFIED GOOD — DO NOT CHANGE THIS

Zero cookies, zero trackers, zero third-party requests

I searched the whole source tree for analytics, tag managers, pixels, session recorders, chat widgets, reCAPTCHA, embedded video and external CDNs. There are **none**. The page sets no cookies. Fonts come through `next/font/google`, which downloads them at build time and serves them from your own server — so no visitor IP ever reaches Google, which is the single most common GDPR complaint against websites in Europe.

The consequence: this site legitimately does not need a cookie banner. That is worth stating out loud on the page. It is a genuine selling point to a safety or works-council buyer, and it answers an auditor's first question before they ask it.

MUST FIX BEFORE LAUNCH

H1 The website has no privacy notice of its own BLOCKER

The footer and both forms link to a "Privacy Policy" that lives on the cloud app. That document is the notice for the *product*. It never mentions the marketing website, the contact form, the whitepaper form, or the mailer that sends both. Nothing on wergonic.com tells a visitor who the controller is, what happens to what they typed, on what basis, for how long, or how to complain.

It is also **dated 1 December 2022** — almost four years stale — and it is generated boilerplate that is largely about **California** law: the California Customer Records statute, "Shine the Light", authorised agents, opt-out of sale. The GDPR content is a thin generic section bolted on the side.

FIX

Write one real privacy notice for the website and host it on the landing page itself, at `/privacy`. It must be about this site: the two forms, the mailer, the hosting, the retention, the rights. The product notice stays where it is and gets linked from it.

H2 That linked policy actively contradicts what the site does BLOCKER

The policy contains a table of data categories. It declares "**Identifiers — Collected: NO**", where identifiers are defined in that same table as real name, postal address, phone number, IP address, email address. The contact form on this site collects first name, last name, email, phone and company. The table also says the company collects gender, date of birth, and audio/video recordings — none of which appear anywhere on the site.

So the notice is not merely incomplete, it is **wrong in both directions**. An inaccurate notice breaches the fairness and transparency principle in Article 5(1)(a) on its own, before you even get to Article 13.

FIX

Replaced by H1. Do not patch this table — the whole document is generated boilerplate for the wrong jurisdiction and should be rewritten rather than edited.

H3 The whitepaper consent is bundled, and it is never recorded BLOCKER

One mandatory checkbox reads: *"I agree to receive this resource **and occasional updates** from Wergonic."* The download will not proceed unless it is ticked. That is two different purposes — delivering the file the person asked for, and marketing — welded into one required tick. Consent obtained that way is not freely given and not specific, so the marketing consent is invalid.

Worse, the tick is checked in the browser and then **thrown away**. The value is never sent to the server, and the API never looks for it. There is no record of who consented, when, or to what wording — so Article 7(1) cannot be satisfied at all. If anyone ever complains, there is nothing to show.

FIX

Split it. Delivering the requested file needs no consent — it is what they asked for. Add a **separate, optional, unticked** box for marketing. Send that flag to the server together with a timestamp, the IP or a request id, and a version string for the exact consent wording shown, and store it.

H4 The success screen promises a double opt-in that does not exist BLOCKER

After a whitepaper download the page says: *"We've sent a confirmation to your@email — **click the link in it to confirm** and receive future Wergonic insights."*

No such email is sent. The API mails the PDF straight to the address, with no confirmation step and no link. The site is describing a double opt-in process that has not been built — which is both an untrue statement made inside a consent flow, and a missed opportunity, because a real double opt-in would have solved H3 cleanly.

FIX

Either build the confirmation email properly — which is the better answer and gives you a defensible consent record for free — or delete that sentence today. Leaving it as is, is the worst of the three options.

H5 The processors that actually handle enquiries are not disclosed BLOCKER

The Data Protection page carries the heading *"Every party that touches your data — disclosed in full"* and lists three: AWS, Cloudflare, Sentry.

Every contact enquiry and every whitepaper lead is sent through **Inleed** (the SMTP host in the mailer config) and delivered into a **Google Workspace** mailbox — the MX record for wergonic.com is `smtp.google.com`. The site itself runs on **DigitalOcean**, not AWS. None of those three appear on the list. Google in particular sits badly next to the neighbouring claim of "No transfers outside the EU/EEA".

FIX

Either add Google Workspace, Inleed and DigitalOcean to the list, or reword that section so it is explicitly scoped to *worker measurement data in the product* — and then put the website's own processors in the new website privacy notice. The current absolute wording is what makes this a finding.

H6 The whitepaper endpoint will email anyone, on demand, with no limit BLOCKER

POST `/api/whitepaper` takes whatever email address it is given and sends a PDF attachment to it. There is no ownership check, no confirmation, no rate limit and no captcha. Anyone can script it to send Wergonic-branded attachments to a third party's inbox repeatedly, from Wergonic's own domain. `/api/contact` has only a hidden honeypot field, which stops naive bots and nothing else.

This is both an abuse channel and an Article 32 failure — it is a technical measure that should exist and does not. The reputational damage lands on the sending domain, which is also the domain the product's transactional email uses.

FIX

Rate-limit both routes by IP. For whitepapers, confirm the address before sending anything, or send a download link instead of an attachment. Adding a captcha would mean adding a third-party tracker to a site that currently has none — prefer rate limiting and confirmation.

SHOULD FIX

M1 Nothing is ever deleted, and no retention period is stated MEDIUM

There is no database. Enquiries and leads are emailed to a shared inbox and stay there forever. No period is stated anywhere on the site, and none is applied. Article 5(1)(e) needs both.

FIX

Pick a period, publish it, and apply it — for example enquiries deleted after 12 months, marketing consent held until withdrawn plus 3 years of proof. A Google Workspace retention rule on the support inbox does the enforcement.

M2 The site makes strong compliance claims that need verifying MEDIUM

The Data Protection and DPA pages state, as fact: annual penetration testing by an independent EU provider, with results shared under NDA; breach notification within 24 hours; a DPIA template included for customers; quarterly access reviews; twice-yearly incident-response drills; mandatory security training for every employee; a DPA at "v1.2, in force"; and a "GDPR Compliant" badge in the footer.

These are contractual representations to enterprise buyers, not marketing copy. If any is not true today, it is a misrepresentation that a procurement team will test in due diligence and that a regulator would read as an aggravating factor. I have no way to verify them from the code — that is a question for Farhad.

FIX

Go through the list with Farhad. Anything true stays. Anything not yet true gets softened to intent ("we are working towards") or removed. The 24-hour breach commitment in particular is a promise three times stricter than the law requires and it will be held to.

M3 The contact form's notice is one sentence and covers almost nothing MEDIUM

It reads: *"By submitting this form you agree to our Privacy Policy. We use your details only to reply to this enquiry."* The second half is good and honest. The first half is the problem — a privacy policy is not something you agree to, it is something you are informed of, and the linked document does not describe this form anyway.

Missing at the point of collection: who the controller is, the legal basis, how long it is kept, who else sees it, and the right to object and to complain to IMY. This contextual just-in-time notice is precisely the focus of the 2026 enforcement action.

FIX

Replace with a short factual block: who we are, why we hold this, on what basis, for how long, who else touches it, your rights, link to the full notice. Four lines is enough.

M4 Lead details are written to browser storage without asking MEDIUM

After a whitepaper download the visitor's name, email, company, industry and job title are written to `localStorage` under `wg_lead_v1`, to pre-fill the form next time. Nobody is told and nobody is asked.

The theme preference and the offline service-worker cache are both fine — a preference the user set, and storage needed to deliver the service. This one is a convenience, so it falls under the consent rule for device storage rather than the exemption.

FIX

Simplest option is to drop it — it saves a repeat visitor about fifteen seconds. Otherwise add a small "remember my details on this device" tick, off by default.

M5 No security headers at all MEDIUM

`next.config.mjs` sets redirects and nothing else. There is no Content-Security-Policy, no Strict-Transport-Security, no X-Content-Type-Options, no Referrer-Policy and no Permissions-Policy. Referrer-Policy matters here specifically: without it, full URLs leak to any external site a visitor clicks through to.

FIX

One `headers()` block in `next.config.mjs`. A tight CSP is genuinely easy on this site because there are no third-party scripts to allow — the absence of trackers pays off twice.

M6 Four different contact addresses across the site MEDIUM

The footer shows `farhad@wergonic.com`. The Data Protection page gives `support@wergonic.com` for privacy, legal and DPO matters. The contact form's error message tells people to write to `contact@wergonic.com`. The linked privacy policy uses `info@wergonic.com` for rights requests, and names the DPO as Farhad Abtahi at yet another address. Article 13 wants one clear controller contact and one clear DPO contact.

FIX

One address for privacy and rights, published consistently everywhere. `privacy@wergonic.com` aliased to the support inbox is the clean version, and it also stops rights requests landing in a personal mailbox.

M7 The footer is missing the address and the VAT number MEDIUM

The footer has the legal name and org.nr — *© 2026 Wergonic AB · Org.nr 559201-5530* — plus an email and "Stockholm, Sweden". The Swedish e-commerce act also requires a **geographic address** and the **VAT number**. "Stockholm, Sweden" is a location, not an address, and the registered address on the privacy policy is in fact Kvalitetsvägen 12, 146 31 Tullinge.

FIX

Add the street address and `SE559201553001` -style VAT number to the footer, or to a short legal page linked from it.

MINOR

ITEM	WHAT IT IS
L1	Say on the site that it sets no cookies and runs no analytics. It is true, it is unusual, and it is the fastest way to close the question for a buyer's security review.
L2	The consent-checkbox error message is the untranslated literal string <code>"required"</code> , so a user who skips the box sees a raw developer token.
L3	"Your details are kept private and GDPR-compliant" under the download form is a vague claim that says nothing. Replace with the specific sentence: what you do with it and for how long.
L4	"No spam, unsubscribe anytime" appears above the whitepaper list, but there is no unsubscribe mechanism anywhere. It becomes true once H3 is fixed — not before.

ITEM	WHAT IT IS
L5	The About page publishes five people's names, roles, photos, bios and profile links. That is fine on legitimate interest, but confirm each person has seen it and knows they can ask for removal. Board members and academics are the ones who tend to object.

Part C · The site the public sees right now

IMPORTANT

wergonic.com does not serve the new landing page — it redirects to the old WordPress site

wergonic.com returns a 301 to wergonic.se, a WordPress site running Elementor, WPForms and Contact Form 7. Everything in Part B describes a site that is not live yet. Everything below is live today, on the domain on every business card and in every email signature.

C1 The privacy policy is the unedited WordPress sample template URGENT

The page at `/privacy-policy-2/` is the default text WordPress ships with, published without a single edit. It opens *"Who we are — Our website address is: <https://wergonic.se>"* and then discusses blog comments, Gravatar avatars, EXIF location data in uploaded images, and login cookies for site administrators.

It does not mention the WPForms contact forms that are actually on the page. It does not name Wergonic AB, give the org.nr or an address, state a single legal basis, give a retention period for form submissions, name a DPO, or mention the right to complain to IMY. It says comment data is *"retained indefinitely"*.

FIX

This is the single most urgent item in this document, and it is a copy-paste job. Write the real notice once (H1) and put it on both sites today.

C2 Google Fonts is hotlinked from Google's servers URGENT

The theme pulls fonts from `fonts.googleapis.com` and `fonts.gstatic.com` on every page load, with no consent. Every visitor's IP address is transmitted to Google as a result. This is the most warning-lettered GDPR issue in Europe: a Munich court awarded damages for exactly this in 2022 and it started an industry of automated claim letters, particularly out of Germany — which is a market Wergonic sells into.

FIX

Self-host the font files. The new site already does this correctly, which is why it does not appear in Part B.

C3 Running end-of-life PHP URGENT

The server reports `PHP/7.4.33`. PHP 7.4 reached end of life in November 2022 and has had **no security patches for nearly four years**. This server receives and stores contact form submissions. Under Article 32 that is a failure to apply appropriate technical measures, and unlike the paperwork items it is an actual breach risk rather than a documentation gap.

C4 No consent mechanism of any kind MEDIUM

There is no cookie banner and no consent layer. Given the Google Fonts calls and the YouTube player script that loads on the page, third-party requests happen before the visitor has any say. Fixing C2 removes most of this; the YouTube player needs checking to confirm it only loads on click.

C5 Two different privacy policies are live simultaneously MEDIUM

The WordPress template at `wergonic.se/privacy-policy-2/` and the 2022 Termly document at `cloud.wergonic.com/privacy-policy`. They describe different companies doing different things, and the web app links to a *third* URL — `wergonic.se/privacy-policy-2/` — from its login screens.

C6 No security headers on the live site either MEDIUM

No HSTS, no CSP, no X-Content-Type-Options, no Referrer-Policy. Same as M5, on an unpatched server.

Part D · What to do, in order

THIS WEEK — THE LIVE SITE IS WHAT IS EXPOSED

- 1 **Write the real privacy notice once.** Controller: Wergonic AB, org.nr 559201-5530, Kvalitetsvägen 12, 146 31 Tullinge. DPO: Farhad Abtahi, one address. Then: what each form collects, the purpose and legal basis for each, the recipients (Google Workspace, Inleed, DigitalOcean, Cloudflare), the retention period, the rights, and the right to complain to IMY. Publish it on wergonic.se immediately, and ship it with the new site.
- 2 **Self-host the fonts on wergonic.se** and remove the Google calls.
- 3 **Update PHP** on the WordPress host.

If the new site is within a few weeks of launch, cutting over sooner is a cleaner fix than repairing WordPress — it retires C2, C3, C4 and C6 in one move. That is a scheduling call, but the privacy notice cannot wait for it either way.

BEFORE THE NEW SITE GOES LIVE

- 1 Ship the privacy notice at `/privacy` and link it from the footer and both forms, replacing the cloud-app link. H1 H2
- 2 Split the whitepaper consent into required delivery and optional marketing, and record the marketing consent server-side with timestamp and wording version. H3
- 3 Build the confirmation email, or delete the sentence that promises it. H4
- 4 Add a working unsubscribe path. H3 L4
- 5 Rate-limit both API routes; confirm the address before mailing a whitepaper, or send a link instead of an attachment. H6
- 6 Fix the sub-processor list, or scope its wording to product data. H5
- 7 Add security headers in `next.config.mjs`. M5

SHORTLY AFTER

- 1 Go through the compliance claims with Farhad and correct anything not true today. M2
- 2 Set and apply a retention rule on the support inbox. M1
- 3 One privacy address everywhere. M6
- 4 Full address and VAT number in the footer. M7
- 5 Proper just-in-time notice under each form. M3
- 6 Drop the localStorage lead cache, or make it opt-in. M4
- 7 State on the site that it uses no cookies and no analytics. L1
- 8 Write the Article 30 record of processing. It is internal, it takes an afternoon, and it is the first document a regulator asks for.

WORTH SAYING

The hard part is already done

Most GDPR remediation on a marketing site is about ripping out tracking that marketing does not want to lose. There is none of that here. Every finding above is a document to write or a form to rewire — no architectural change, no vendor to replace, no feature to sacrifice. Two to three days of developer time plus half a day of writing closes the whole list.

Wergonic — Landing Page GDPR Audit · 3 September 2026

Sources checked: `wergonic-landing-page` at `main / f66badc`; `wergonic-web-apps` client-panel privacy notice; live responses from `wergonic.com`, `wergonic.se` and `cloud.wergonic.com`; DNS MX and SPF records for `wergonic.com`. Legal basis for the requirements in Part A: GDPR Articles 5, 6, 7, 12–22, 28, 30, 32, 44–49; ePrivacy Directive Article 5(3); EDPB Coordinated Enforcement Framework 2026 (transparency and information obligations); Lag (2002:562) om elektronisk handel §8; marknadsföringslagen §19.

This is an engineering and process review, not legal advice. Have the final privacy notice read by a Swedish data-protection lawyer before publishing.